

Cyber Threat Intelligence

Executive Briefing

Report Date: July 04, 2026

Generated: 2026-07-04 11:41 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
3	12	4	1	20

2. Executive Summary

This briefing details the security assessment results for July 04, 2026, encompassing a total of 20 analyzed vulnerabilities. The distribution consists of 3 Critical, 12 High, 4 Medium, and 1 Low severity findings, resulting in a residual risk posture categorized as Critical based on CVSS v3.1 impact criteria. The primary threat, CVE-2026-52830 (Token Traversal in fast-mcp-telegram), necessitates immediate attention due to a bearer token path traversal vulnerability that compromises Telegram session integrity. Given the elevated exploitation potential of the identified critical assets, the organization is currently operating under a heightened state of defensive readiness. We recommend an immediate, accelerated remediation posture to mitigate exposure across all high-risk surface areas.

3. Critical Action List

- CVE-2026-52830: Initiate emergency patch deployment for the fast-mcp-telegram component within 24 hours to remediate the bearer token path traversal vulnerability.
- CVE-2026-49360: Disable the Recce server SQL interface immediately and implement strict authentication controls by the next business cycle.
- CVE-2026-49352: Rotate all JWT secrets for the 9router infrastructure and enforce secure key management protocols within 48 hours.
- CVE-2026-54617: Apply the vendor-provided security update to the LaunchServer FileServerHandler to mitigate unauthorized path traversal within 72 hours.
- CVE-2026-2092: Reconfigure Keycloak SAML validation logic to mandate strict encryption checks within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-52830	Token Traversal in fast-mcp-teleg...	9.8	Critical	95/100	CWE-22

CVE-2026-49360	SQL Injection and File I/O in Rec...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	JWT Authentication Bypass in 9rou...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Path Traversal in LaunchServer Fi...	7.5	High	88/100	CWE-22
CVE-2026-2092	SAML Assertion Validation Bypass ...	7.7	High	79/100	CWE-1287
CVE-2026-46599	Resource Exhaustion in golang.org...	7.5	High	78/100	CWE-770
CVE-2026-50200	Credential Exposure in Steeltoe S...	7.5	High	78/100	CWE-200
CVE-2026-50196	Eureka Registry Poisoning in Stee...	8.2	High	78/100	CWE-20
CVE-2026-52834	Integer Overflow in jxl-grid 32-b...	8.6	High	76/100	CWE-122
CVE-2026-50194	Management Port Bypass in Steeltoe	8.6	High	74/100	CWE-288
CVE-2026-50201	Privileged Actuator Access in Ste...	6.5	Medium	69/100	CWE-269
CVE-2026-49353	Local Access Gate Bypass in 9rout...	7.5	High	68/100	CWE-290
CVE-2026-52792	Source Disclosure in Algernon via...	7.5	High	68/100	CWE-69
CVE-2026-49289	DoS via XPath Transformation in S...	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Corruption in Zebra Addre...	7.5	High	68/100	CWE-617
CVE-2026-49284	SAML Response Validation Flaw in ...	7.4	High	64/100	CWE-345
CVE-2026-50202	JWKS Cache Poisoning in Steeltoe	5.0	Medium	63/100	CWE-668
CVE-2026-50267	Insecure TLS Key Storage in Steel...	5.5	Medium	52/100	CWE-312
CVE-2026-49292	Persistent Initialization Endpoin...	5.4	Medium	34/100	CWE-862
CVE-2026-50268	Weak RSA Padding in Steeltoe	3.7	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-52830

Finding: Token Traversal in fast-mcp-telegram

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 95/100 | CWE: CWE-22

MITRE ATT&CK: T1550, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The fast-mcp-telegram component suffers from a bearer token path traversal vulnerability that ignores Telegram session protections. By manipulating the token input, an attacker can access data or endpoints restricted to other sessions. This bypasses the session-level security controls enforced by the application.

Proof of Concept (PoC):

An unauthenticated attacker sends a request to the fast-mcp-telegram interface with a maliciously crafted Bearer token

containing path traversal characters. The application processes the token without validating that the path is contained within the intended session scope. The attacker successfully gains access to private Telegram session data or management functions. This results in full compromise of the affected Telegram session.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52830>

CVE-2026-49360

Finding: SQL Injection and File I/O in Recce

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

MITRE ATT&CK: T1190, T1496

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server implements an unauthenticated SQL execution interface that interfaces with DuckDB. This vulnerability stems from a lack of input validation on query parameters, which permits unauthorized local file read and write operations. An unauthenticated remote attacker can leverage this access to exfiltrate sensitive system files or manipulate application configuration data.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts a malicious DuckDB SQL statement designed to interact with the local filesystem. The attacker submits this payload via the Recce server's query execution endpoint. The server processes the command with elevated privileges, ignoring input constraints. This results in the ability to read arbitrary sensitive files or write malicious configurations to the server disk.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49360>

CVE-2026-49352

Finding: JWT Authentication Bypass in 9router

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

MITRE ATT&CK: T1552, T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

9router utilizes a hardcoded, publicly known default fallback secret for JSON Web Token (JWT) signature verification.

Because the secret is hardcoded, any attacker can sign arbitrary tokens to impersonate any user on the system. This leads to complete authentication bypass and unauthorized access to protected resources.

Proof of Concept (PoC):

An unauthenticated remote attacker retrieves the hardcoded JWT secret from the 9router application binary. The attacker constructs a forged JWT containing an administrative user ID and signs it using the discovered secret key. The attacker sends a request to a protected API endpoint with the forged token in the Authorization header. The server trusts the signature, resulting in full unauthorized administrative access to the platform.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49352>

CVE-2026-54617

Finding: Path Traversal in LaunchServer FileServerHandler

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 88/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The FileServerHandler in LaunchServer incorrectly handles input paths, resulting in an unauthenticated path traversal vulnerability. This flaw arises from insufficient sanitization of user-provided file path parameters, allowing traversal outside of designated web directories. An unauthenticated attacker can exploit this to read sensitive arbitrary files from the host server filesystem.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP GET request to the file serving endpoint with a path parameter containing '..%2f' sequences. The FileServerHandler fails to validate the requested path against the restricted root directory. The application resolves the path to a sensitive file such as /etc/passwd and returns its contents to the attacker. This results in the unauthorized disclosure of sensitive host system information.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54617>

CVE-2026-2092

Finding: SAML Assertion Validation Bypass in Keycloak

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 79/100 | CWE: CWE-1287

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low

Attack Complexity	Low
User Interaction	None

Scope	Changed
Integrity Impact	None

Confidentiality Impact	High
Availability Impact	None

Description:

Keycloak fails to properly validate encrypted SAML assertions, leading to unauthorized access. The flaw allows attackers to bypass integrity checks on the assertion structure, potentially enabling the use of malicious identity data. This allows an unauthorized entity to gain access to resources protected by the Keycloak identity provider.

Proof of Concept (PoC):

An attacker intercepts an encrypted SAML exchange and modifies the underlying assertion content while keeping the structure valid but unverified by the Keycloak processor. The attacker presents this assertion to the service provider, which trusts the manipulated identity data provided by Keycloak. The application grants the attacker access based on the forged claims. This results in an unauthorized elevation of privilege.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2092>

CVE-2026-46599

Finding: Resource Exhaustion in golang.org/x/image/tiff

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The PackBits decompression function in golang.org/x/image/tiff suffers from improper input validation regarding compressed buffer lengths. This flaw allows a maliciously crafted TIFF image to cause excessive CPU and memory consumption during the decompression process. This results in a denial-of-service condition where the application becomes unresponsive due to memory exhaustion.

Proof of Concept (PoC):

An attacker uploads a specially crafted TIFF image file containing a maliciously inflated PackBits compression stream. The golang.org/x/image/tiff library attempts to decompress this stream while failing to verify resource requirements against defined bounds. The application quickly consumes all available memory resources while processing the image. This results in a denial-of-service, rendering the image processing service unavailable to legitimate users.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-46599>

CVE-2026-50200

Finding: Credential Exposure in Steeltoe Sanitizer

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-200

MITRE ATT&CK: T1552, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter connection strings, leading to the accidental exposure of embedded database passwords. This vulnerability occurs when the application configuration is dumped through insecure endpoints or log files. An attacker can recover cleartext credentials to compromise the backend database.

Proof of Concept (PoC):

An attacker requests the /actuator/env endpoint which displays the application's configuration. The Steeltoe sanitizer fails to mask the connection strings, displaying full database credentials in plaintext. The attacker retrieves these credentials and uses them to connect directly to the backend database. This results in full unauthorized access to the application's data stores.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50200>

CVE-2026-50196**Finding: Eureka Registry Poisoning in Steeltoe**

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 78/100 | CWE: CWE-20

MITRE ATT&CK: T1498, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

Steeltoe.Discovery.Eureka accepts unrecognized DataCenterInfo.Name attributes, allowing an attacker to poison the entire registry fetch process. This allows an attacker to inject fake services into the service discovery mechanism. This redirects legitimate traffic to attacker-controlled nodes or causes systemic service failure.

Proof of Concept (PoC):

An attacker registers a malicious service with a crafted DataCenterInfo.Name attribute against the Eureka registry. Steeltoe components fetch the updated registry, which becomes 'poisoned' by the unexpected attribute. The client service unknowingly directs legitimate traffic to the attacker-controlled endpoint. This results in successful interception of internal service communication or total service outage.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50196>

CVE-2026-52834

Finding: Integer Overflow in jxl-grid 32-bit**CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 76/100 | CWE: CWE-122**

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library exhibits an integer overflow vulnerability on 32-bit systems during memory allocation for grid structures. This flaw leads to an out-of-bounds write when subsequent operations process the incorrectly sized buffer. An attacker can trigger this via specially crafted data to achieve arbitrary memory corruption or potential remote code execution.

Proof of Concept (PoC):

An attacker supplies a highly anomalous dimension size in a grid file processed by jxl-grid on a 32-bit architecture. The calculation for the memory buffer allocation overflows the 32-bit integer range, resulting in an undersized allocation. The system then writes data beyond the bounds of this buffer when populating the grid. This results in memory corruption that may be leveraged for arbitrary execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52834>**CVE-2026-50194****Finding: Management Port Bypass in Steeltoe****CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288**

MITRE ATT&CK: T1133, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Steeltoe is vulnerable to management-port isolation bypass via a spoofed Host header. The application fails to properly validate the connection origin, allowing attackers to access management-specific endpoints from external networks. This compromises the segregation of management traffic from application traffic.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the management port of a Steeltoe service. The attacker sends a request with a spoofed 'Host' header matching the expected management internal address. The service incorrectly routes the request to the management interface, bypassing the isolation check. This results in the attacker gaining unauthorized access to internal management tools.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50194>

CVE-2026-50201

Finding: Privileged Actuator Access in Steeltoe

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-269

MITRE ATT&CK: T1068, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Sensitive actuators in Steeltoe, such as those for heap dumps and environment details, are secured only by the 'Restricted' permission level. This configuration is insufficient to prevent unauthorized access to sensitive application metadata and system internals. An attacker with minimal access can retrieve configuration secrets or memory snapshots.

Proof of Concept (PoC):

An authenticated user with low-level 'Restricted' permissions navigates to the /actuator/heapdump endpoint. The system permits access to the endpoint, failing to check for a higher privilege tier required for such sensitive information. The attacker downloads the heap dump containing raw memory data. This results in the extraction of sensitive credentials, keys, and session tokens stored in the memory.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50201>

CVE-2026-49353

Finding: Local Access Gate Bypass in 9router

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

MITRE ATT&CK: T1133, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The 9router application exhibits an incomplete patch regarding its Local-Only Access Gate mechanism. By manipulating the HTTP Host header, an attacker can bypass intended network-based access restrictions. This failure allows unauthorized entities to access administrative endpoints typically reserved for local network traffic.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a protected management endpoint on 9router. The attacker sends an HTTP request with a modified 'Host' header set to 'localhost' or an internal IP address. The application logic trusts the spoofed header for access control decisions instead of verifying the connection source. This results in the bypass of perimeter security, granting access to restricted internal functions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49353>

CVE-2026-52792

Finding: Source Disclosure in Algernon via NTFS Filenames

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

MITRE ATT&CK: T1083, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon server exhibits a file source disclosure vulnerability on Windows platforms when accessed via specific NTFS alternate stream patterns or filenames. The server fails to properly sanitize requests for script files, allowing access to the underlying source code instead of execution. An attacker can leverage this to steal sensitive server-side logic and environment credentials.

Proof of Concept (PoC):

An attacker targets a known script file path on an Algernon server running on Windows. The attacker appends a specific NTFS artifact, such as a trailing colon or stream identifier, to the requested filename. The server's file handler logic fails to trigger the script interpreter and instead serves the raw content of the file. This results in the disclosure of server-side source code to the remote attacker.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52792>

CVE-2026-49289

Finding: DoS via XPath Transformation in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service attack due to inefficient processing of XPath transformations within SAML assertions. By submitting deeply nested or complex XPath expressions, an attacker can consume excessive server-side resources. This results in a service crash or significant latency that impairs accessibility for legitimate users.

Proof of Concept (PoC):

An unauthenticated attacker constructs a malicious SAML assertion containing a computationally expensive XPath expression. The attacker transmits this request to the SimpleSAMLphp assertion consumer service. The server spends massive CPU cycles attempting to resolve the malicious expression, leading to a hang or resource exhaustion. This results in the denial of authentication services to all legitimate users.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Corruption in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book application suffers from memory pool (mempool) misbehavior when processing IPv4-mapped addresses. This flaw, introduced during a recent update, leads to potential memory corruption or application abortion. An attacker can exploit this via carefully structured inputs to force an application crash, causing a denial-of-service condition.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a network request containing a malformed IPv4-mapped address format to the Zebra Address Book service. The application attempts to parse this input and incorrectly manages the corresponding memory pool. The inconsistency triggers a segmentation fault or a memory assertion failure. This results in an immediate crash of the service, causing an effective denial-of-service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-52829>

CVE-2026-49284

Finding: SAML Response Validation Flaw in SimpleSAMLphp

CVSS v3.1 Score: 7.4 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
---------------	---------

Attack Complexity	High
-------------------	------

Privileges Required	None
Scope	Unchanged
Integrity Impact	High

User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The SimpleSAMLphp SP fails to properly link unsigned Response/InResponseTo attributes with signed assertions lacking SubjectConfirmationData/InResponseTo. This inconsistent validation logic allows an attacker to inject an assertion from an unexpected Identity Provider. This permits potential identity impersonation or bypass of configured authentication flows.

Proof of Concept (PoC):

An unauthenticated attacker intercepts a legitimate authentication session request. The attacker presents a crafted, unsigned SAML Response generated by a malicious IdP while omitting the SubjectConfirmationData/InResponseTo field. The SimpleSAMLphp SP erroneously validates the assertion because the internal linkage check is incomplete. This results in the attacker successfully authenticating to the target SP as an arbitrary user.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49284>

CVE-2026-50202

Finding: JWKS Cache Poisoning in Steeltoe

CVSS v3.1 Score: 5.0 | Severity: Medium | Urgency Score: 63/100 | CWE: CWE-668

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

Steeltoe's JWKS cache is shared globally across different schemes and is never invalidated during the application lifecycle. This persistence allows a potential attacker to keep outdated or malicious keys in memory, bypassing security updates. This leads to persistent, unauthorized authentication success even after keys have been revoked.

Proof of Concept (PoC):

An attacker with low privileges identifies that the JWKS endpoint is cached indefinitely by the Steeltoe service. The attacker manages to temporarily inject a rogue key into the cache through an exploit or configuration flaw. Because the cache is never invalidated, the rogue key remains active indefinitely. This results in continued unauthorized access to the application long after the original incident.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50202>

CVE-2026-50267

Finding: Insecure TLS Key Storage in Steeltoe

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 52/100 | CWE: CWE-312

MITRE ATT&CK: T1552, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe writes TLS private keys to the /tmp directory with insecure permissions and fails to clean them up after use. This creates a persistent risk where any local user on the host system can read the sensitive key material. An attacker can exploit this for unauthorized interception of TLS traffic.

Proof of Concept (PoC):

A local user with low privileges gains access to the host server running Steeltoe. The user monitors the /tmp directory and identifies a file containing TLS private keys left behind by the application process. The user copies the key material to an external location for offline analysis. This results in the ability to decrypt existing TLS traffic or perform man-in-the-middle attacks.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50267>

CVE-2026-49292

Finding: Persistent Initialization Endpoint in Kiwi TCMS

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 34/100 | CWE: CWE-862

MITRE ATT&CK: T1068, T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The /init-db/ page in Kiwi TCMS fails to disable itself after the initial database configuration has been completed. This oversight allows external actors to trigger re-initialization routines or probe the current state of the backend store. This flaw creates a vector for potential service disruption or state corruption, requiring an authenticated session or specific conditions to trigger.

Proof of Concept (PoC):

An authenticated user navigates to the /init-db/ endpoint after the initial system setup is finished. The server fails to perform an authorization check or verify if the initialization process has already occurred. The application re-executes the database initialization routines upon receiving a GET or POST request to this endpoint. This results in the accidental or malicious destruction of current test data stored within the database.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49292>

CVE-2026-50268

Finding: Weak RSA Padding in Steeltoe

CVSS v3.1 Score: 3.7 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Steeltoe improperly handles OAEP settings, silently defaulting to the weaker PKCS#1 v1.5 padding scheme. This downgrade exposes sensitive data to padding oracle attacks. An attacker can leverage this to recover plaintext from encrypted communication.

Proof of Concept (PoC):

An attacker monitors encrypted traffic between client and server using Steeltoe components. The attacker initiates a series of requests that force the server to decrypt data using the fallback PKCS#1 v1.5 padding scheme. By observing error responses, the attacker decrypts targeted sensitive data bit-by-bit. This results in the compromise of encrypted data due to weak cryptographic implementations.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>